

Risk-Impact Prioritisation Matrix

1. Purpose

This document outlines a risk prioritisation framework for AutoAudit using a likelihood × impact matrix aligned with CIS, NIST, and ISO 27001.

2. How the Matrix Works

Likelihood (how often could this happen?)

- **Almost Certain**: very likely, nothing currently stopping it
- **Likely**: will probably happen at some point
- **Possible**: could happen if controls are weak
- **Unlikely**: not expected but not impossible
- **Rare**: low chance of happening

Consequence (what are the consequences if the likelihood event happens?)

- **Insignificant**: barely noticeable, easily recovered
- **Minor**: small disruption, fixable quickly
- **Moderate**: some impact on project or tenant security
- **Major**: significant breach or compliance failure
- **Severe**: data loss, regulatory breach, or project-stopping incident

3. Probability - Impact Matrix

	Consequence				
Likelihood	Insignificant	Minor	Moderate	Major	Severe
Almost Certain	Medium	High	High	Extreme	Extreme
Likely	Medium	Medium	High	Extreme	Extreme
Possible	Medium	Medium	High	High	Extreme
Unlikely	Low	Medium	Medium	High	High
Rare	Low	Low	Medium	High	High

4. Heatmap Guide:

Rating	Colour	What it means	Action required
Extreme		High chance of a serious breach or compliance failure	Fix immediately. Document it
High		Will probably happen and cause significant problems	Fix within 7 days. Assign to a team member and track in Planner.
Medium		Could happen and would have a moderate impact	Fix within 30 days. Log it, schedule it,
Low		Unlikely to happen and easy to recover from.	Monitor each trimester .

5. AutoAudit Risk Impact Table

ID	Risk Description	Likelihood	Consequence	Rating	Mitigation Strategy	Success Metric
R-01	MFA not enforced on M365 admin accounts	Almost Certain	Severe	Extreme	Turn on MFA for all admin accounts through Conditional Access and add it as an automatic check in the scan	admins without MFA = 0
R-02	Legacy authentication (Basic Auth) still enabled	Likely	Major	Extreme	Block old-style login methods through Conditional Access and check this is working via the Graph API scan	Legacy auth blocked = 100%
R-03	Global admin roles assigned without time-limiting	Likely	Major	Extreme	Set up PIM so admin access is time-limited and flag any permanent global admin accounts in the dashboard	Permanent global admins = 0
R-04	External sharing enabled across all SharePoint sites	Likely	Severe	Extreme	Change the sharing setting to approved guests only and show an alert on the dashboard if it gets turned back on	Sites with open sharing = 0
R-05	Guest accounts not reviewed regularly	Possible	Major	High	Do a guest account review every trimester and show the last review date in the AutoAudit dashboard	Review done each trimester = Yes
R-06	FastAPI endpoints exposed without authentication on dev environment	Possible	Major	High	Add login checks to all API routes and make sure the dev environment is not open to the internet	Unauthenticated endpoints = 0
R-07	No production environment, scanning against dev environment only	Likely	Moderate	High	Set up a proper cloud environment for production and get a long-term M365 test account sorted	Production environment live = Yes
R-08	CI/CD pipeline not set up, no automated build checks	Possible	Moderate	High	Set up GitHub Actions to automatically build and test the project once the infrastructure is ready	Pipeline running = Yes
R-09	PostgreSQL scan results not encrypted at rest	Possible	Major	High	Turn on database encryption and double-check the storage settings are secure	Encryption at rest = Yes
R-10	Redis cache not secured with password or TLS	Possible	Moderate	High	Add a password and TLS to Redis and check this is working as part of the pipeline	Redis secured = Yes
R-11	Weak password settings not being picked up in scans	Likely	Major	Extreme	Add a password policy check to the scan and flag any environments that do not meet the minimum requirements	Environments failing check = 0
R-12	M365 Unified Audit Log not turned on	Likely	Major	Extreme	Make sure every scan checks whether the audit log is on and shows a clear warning if it is not	Audit log on = 100%
R-13	Audit log kept for less than 90 days	Possible	Moderate	High	Add a retention check to the scan and recommend keeping logs for at least a year	Retention >= 365 days = Yes
R-14	Handover documents not complete for new team members	Unlikely	Moderate	Medium	Finish the onboarding guide before new members join at the start of T1 2026	Onboarding guide done = Yes
R-15	Team meeting notes and decisions not consistently recorded	Unlikely	Minor	Medium	Use the Teams channel to log notes after every meeting and rotate who writes them	Notes logged each meeting = Yes
R-16	Compliance reports hard to read for non-technical users	Unlikely	Insignificant	Low	Add short plain-English summaries and use colour coding so the results are easy to understand at a glance	User feedback = satisfactory

6. AutoAudit Risk Impact Heat Map

Shows where the risks are placed in the heatmap, this can help to see at a glance which areas need the most attention.

	Consequence				
Likelihood	Insignificant	Minor	Moderate	Major	Severe
Almost Certain	—	—	—	—	R-01
Likely	—	—	R-07	R-02, R-03, R-11, R-12	R-04
Possible	—	—	R-08, R-10, R-13	R-05, R-06, R-09	—
Unlikely	R-16	R-15	R-14	—	—
Rare	—	—	—	—	—

7. References List

- [1] G. Porat, "CIS Microsoft 365 v6: What's New and How to Get Full Value From It," Reco.ai, Jan. 2026. [Online]. Available: <https://www.reco.ai/blog/cis-microsoft-365-v6-benchmark-guide>. [Accessed: 27-Mar. 2026].
- [2] Nudge Security, "Top 5 Microsoft 365 Security Misconfigurations — and How to Fix Them," NudgeSecurity.com, Aug. 2025. [Online]. Available: <https://www.nudgesecurity.com/post/top-5-microsoft-365-security-misconfigurations--and-how-to-fix-them>. [Accessed: 26-Mar. 2026].
- [3] Metis Security, "The Most Common Microsoft 365 Misconfigurations We See," Metis-Security.co.uk, Sep. 2024. [Online]. Available: <https://www.metis-security.co.uk/2024/09/18/common-microsoft-365-misconfigurations>. [Accessed: 25-Mar. 2026].
- [4] Microsoft, "Manage Audit Log Retention Policies," Microsoft Learn, 2024. [Online]. Available: <https://learn.microsoft.com/en-us/purview/audit-log-retention-policies>. [Accessed: 24-Mar. 2026].
- [5] P. Somasundaram, "Probability and Impact Matrix: Example, Templates & Differences," KnowledgeHut, Feb. 2025. [Online]. Available: <https://www.knowledgehut.com/blog/project-management/probability-and-impact-matrix>. [Accessed: 21-Mar. 2026].
- [6] Security Scientist, "NIST SP 800-30 Risk Assessment Guide: Process, Steps and Template," SecurityScientist.net, Jul. 2022. [Online]. Available: <https://www.securityscientist.net/blog/guide-to-nist-risk-assessments>. [Accessed: 20-Mar. 2026].